



Report Tecnico: SOC Automation & Incident Response (RDP Brute Force)

Autore: Nicola Cassandra

Data: 19 Marzo 2026

Obiettivo del Progetto: Progettazione e implementazione di una pipeline di Detection & Response automatizzata, integrando un SIEM (Wazuh) e un SOAR (Shuffle) per mitigare l'alert fatigue e ridurre i tempi di triage.

1. Executive Summary

Il presente documento illustra la costruzione di un laboratorio locale *Red vs Blue Team*. L'esercitazione ha dimostrato con successo l'automazione della risposta a un attacco di tipo Brute Force contro il protocollo RDP (Remote Desktop Protocol) su ambiente Windows. Attraverso l'orchestrazione di regole SIEM e flussi webhook SOAR, i tentativi di accesso falliti sono stati intercettati, parsati ed inviati in tempo reale (sotto i 5 secondi) a un canale di comunicazione SOC preposto.

2. Architettura del Laboratorio

L'ambiente è stato isolato all'interno di una rete NAT su VirtualBox:

- **Target (Windows 10 Pro):** IP 192.168.100.11 (Audit Logon abilitato, RDP esposto).
 - **Attaccante (Kali Linux):** IP 192.168.100.3.
 - **SIEM (Wazuh Manager v4.14.2):** IP 192.168.100.9.
 - **SOAR & Alerting:** Shuffler.io (Cloud) integrato con Discord Webhook.
-

3. Fase 1: Preparazione dell'Ambiente e Deploy dell'Agente

Per garantire la visibilità degli eventi di sicurezza sull'endpoint vittima, è stato distribuito l'agente Wazuh tramite PowerShell, associandolo all'IP del Manager.

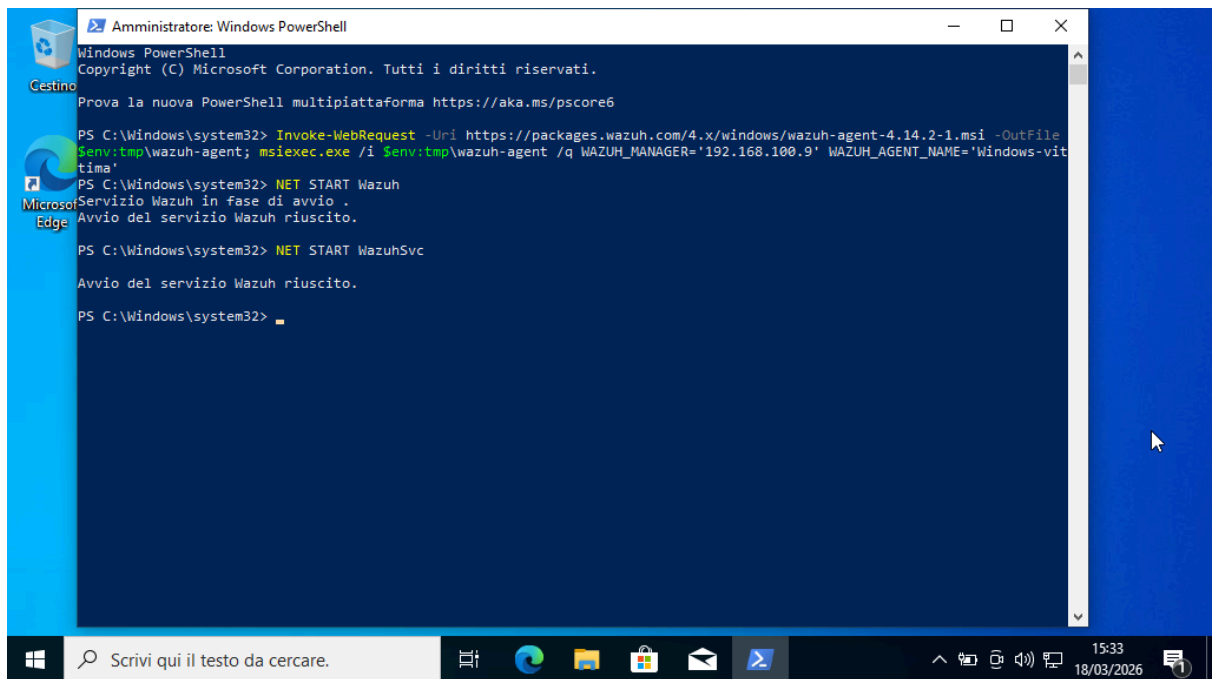


Figura 1: Deploy silenzioso dell'agente Wazuh sull'endpoint Windows tramite PowerShell e avvio del demone in background.

Il corretto arruolamento dell'agente è stato verificato tramite la dashboard Endpoint Summary di Wazuh, confermando lo stato "Active".

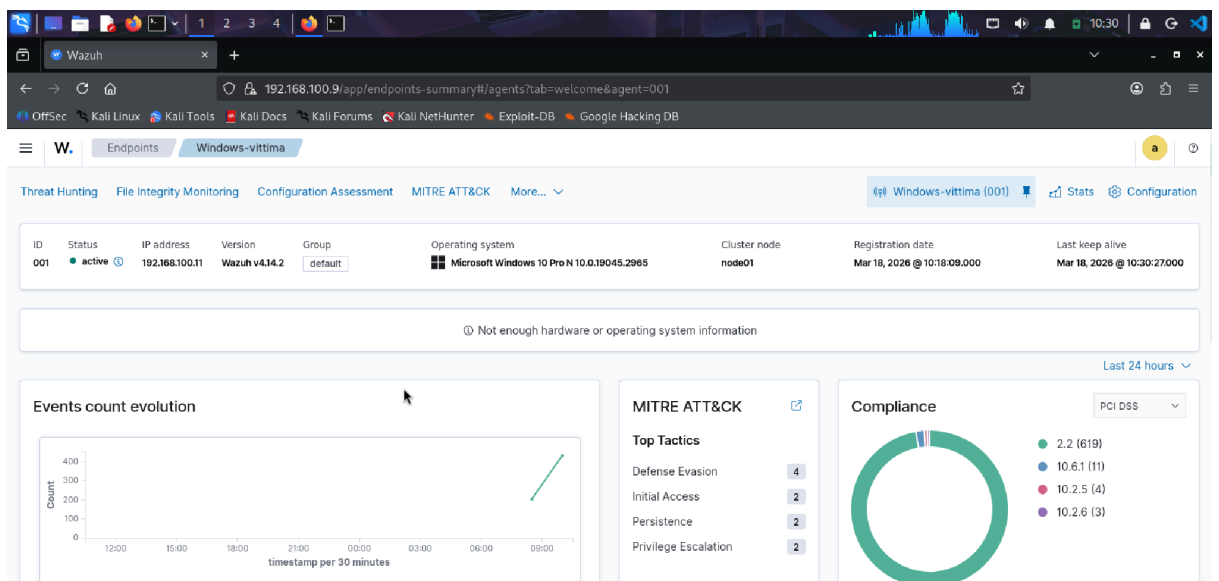
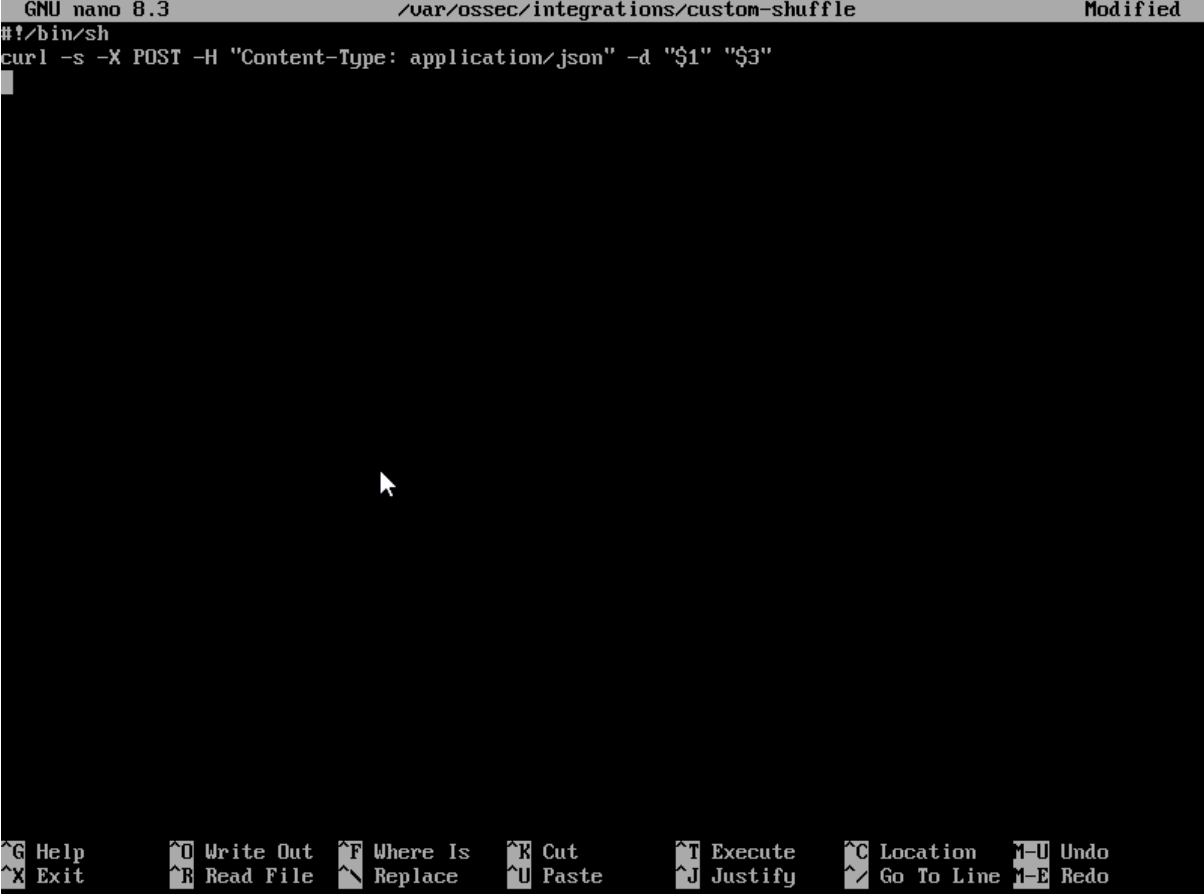


Figura 2: Verifica dell'avvenuto arruolamento dell'agente (Windows-vittima) nella console centralizzata del SIEM.

4. Fase 2: Configurazione dell'Integrazione SIEM-SOAR

Affinché il SIEM possa innescare azioni esterne, è stato ingegnerizzato uno script di integrazione bash personalizzato sul server Wazuh, incaricato di eseguire richieste HTTP POST verso il webhook del SOAR.

A screenshot of a terminal window showing the GNU nano 8.3 text editor. The editor is open to the file `/var/ossec/integrations/custom-shuffle`. The content of the file is a bash script that uses `curl` to send a POST request. The script is as follows:

```
#!/bin/sh
curl -s -X POST -H "Content-Type: application/json" -d "$1" "$3"
```

The nano editor's status bar at the bottom shows various keyboard shortcuts for editing and navigation, such as `^G Help`, `^O Write Out`, `^F Where Is`, `^K Cut`, `^T Execute`, `^C Location`, `^M-U Undo`, `^X Exit`, `^R Read File`, `^_ Replace`, `^U Paste`, `^J Justify`, `^_ Go To Line`, and `^M-E Redo`.

Figura 3: Sviluppo dello script bash di integrazione per l'inoltro del payload JSON dal manager Wazuh all'endpoint webhook.

Successivamente, il demone `wazuh-integrator` è stato configurato nel file `ossec.conf` per attivare lo script unicamente al verificarsi della Rule ID `60122` (Logon Failure).

```
GNU nano 8.3 /var/ossec/etc/ossec.conf
Wazuh - Manager - Default configuration for amzn 2023
More info at: https://documentation.wazuh.com
Mailing list: https://groups.google.com/forum/#!forum/wazuh

<ossec_config>
  <global>
    <jsonout_output>yes</jsonout_output>
    <alerts_log>yes</alerts_log>
    <logall>no</logall>
    <logall_json>no</logall_json>
    <email_notification>no</email_notification>
    <smtp_server>smtp.example.wazuh.com</smtp_server>
    <email_from>wazuh@example.wazuh.com</email_from>
    <email_to>recipient@example.wazuh.com</email_to>
    <email_maxperhour>12</email_maxperhour>
    <email_log_source>alerts.log</email_log_source>
    <agents_disconnection_time>15m</agents_disconnection_time>
    <agents_disconnection_alert_time>0</agents_disconnection_alert_time>
    <update_check>yes</update_check>
  </global>
  <integration>
    <name>custom-shuffle</name>
    <hook_url>https://shuffler.io/api/v1/hooks/webhook_6be34819-3fa2-4fc6-8954-d5c910dcf4f3</hook_url>
    <rule_id>60112</rule_id>
    <alert_format>json</alert_format>
  </integration>
  <alerts>
    <log_alert_level>3</log_alert_level>
    <email_alert_level>12</email_alert_level>
  </alerts>
</ossec_config>
```

Figura 4: Ingegnerizzazione del blocco `<integration>` nel file `ossec.conf` per vincolare l'innescò del SOAR alla Rule ID 60122.

5. Fase 3: Orchestrazione del Workflow (Shuffle) e Alerting

È stato creato un canale SOC dedicato su Discord, generando un Webhook crittografato per la ricezione passiva degli alert.

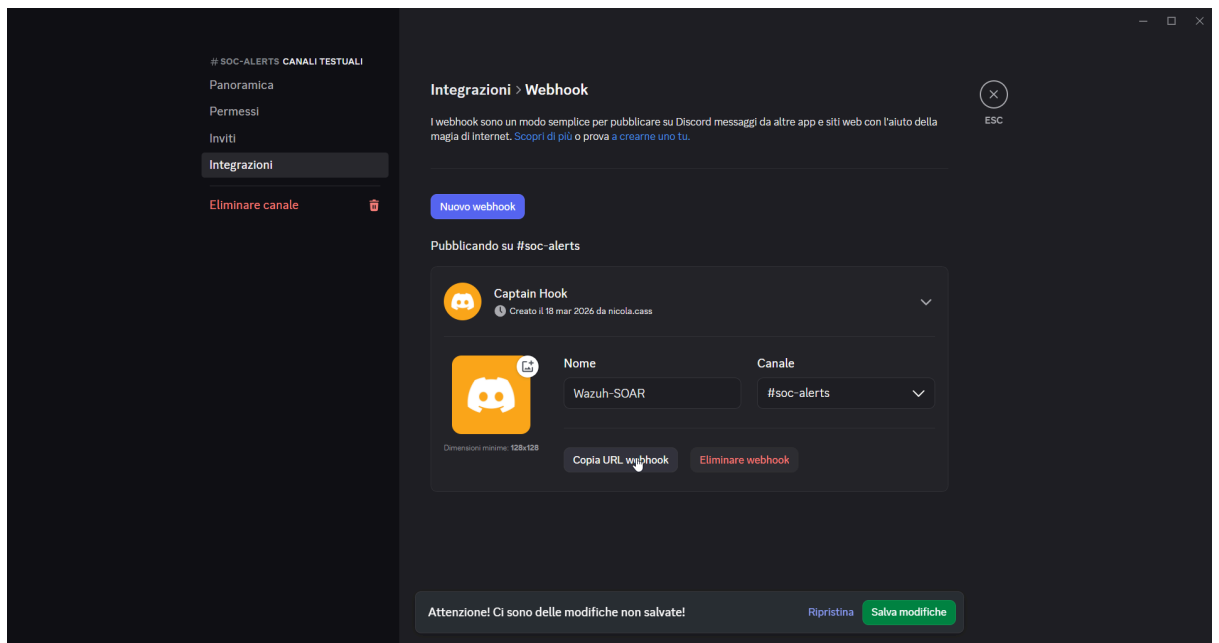


Figura 5: Generazione del Webhook crittografato sul canale Discord dedicato al triage degli alert SOC.

Su Shuffle, il workflow è stato strutturato in due nodi essenziali: un Trigger (Webhook) per ricevere i log grezzi da Wazuh e un'azione HTTP POST. Il nodo HTTP esegue il parsing dinamico del dizionario JSON dei log di Windows, estraendo chiavi specifiche come `$exec.data.win.eventdata.ipAddress` per l'IP e `$exec.data.win.eventdata.targetUserName` per l'utente esca.

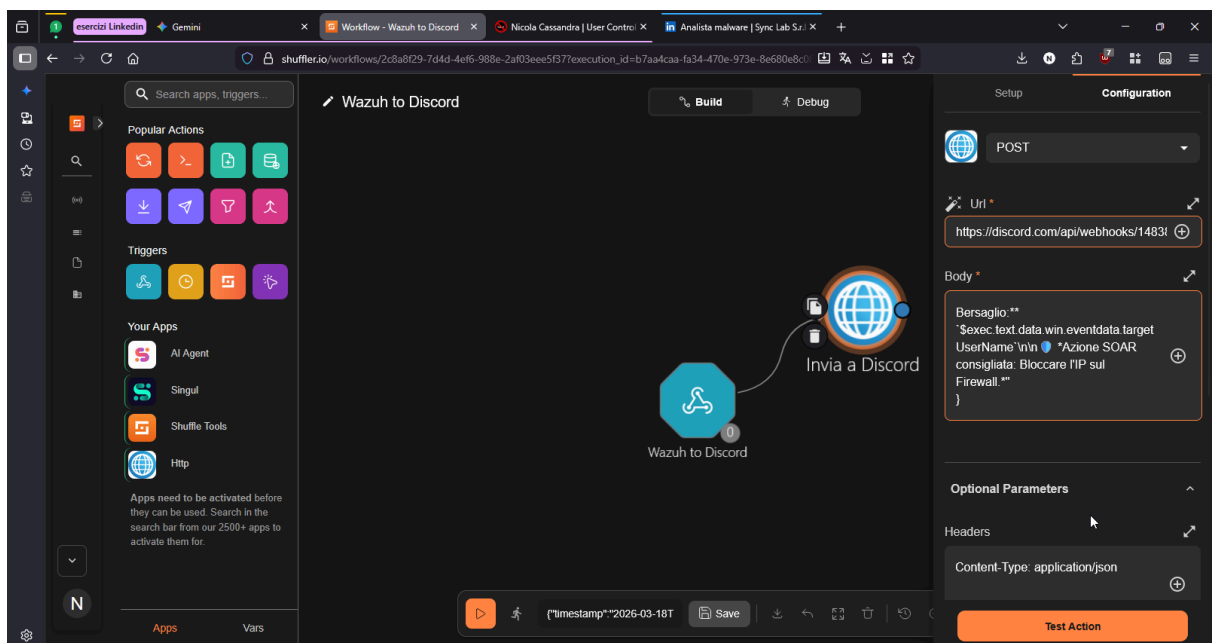


Figura 6: Mappatura dinamica delle variabili JSON (es. estrazione del path proprietario Windows per l'IP) nel nodo HTTP di Shuffle.

6. Fase 4: Simulazione dell'Attacco (Red Teaming)

Per validare la pipeline difensiva, è stata simulata un'intrusione dalla macchina attaccante Kali Linux. È stata dapprima creata una wordlist mirata.

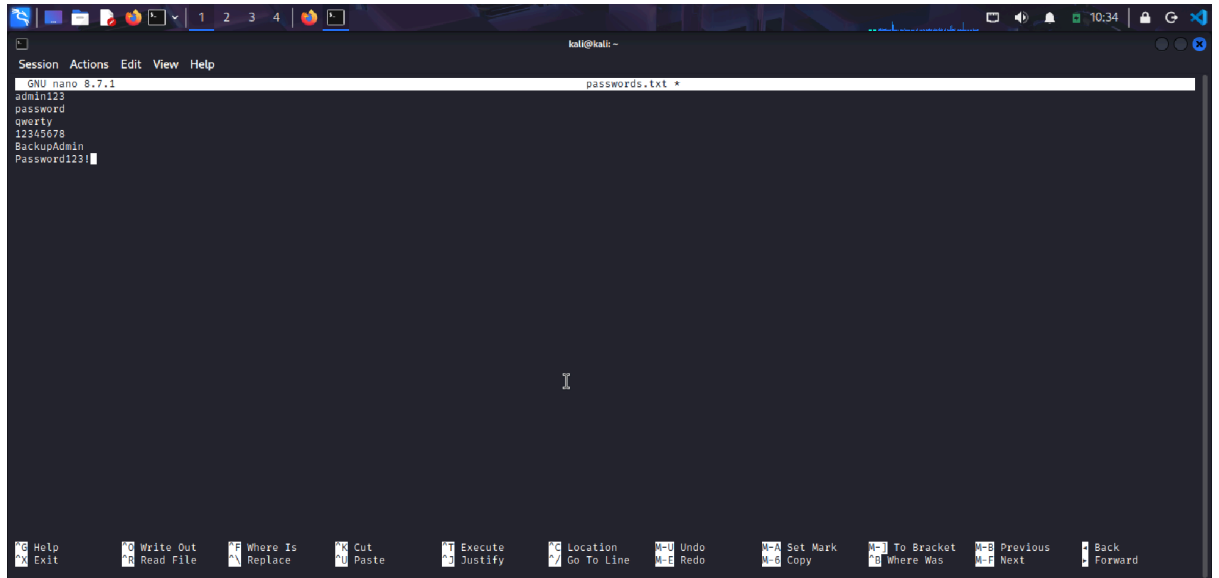


Figura 7: Preparazione della wordlist personalizzata su Kali Linux per la simulazione dell'attacco dizionario.

L'attacco è stato sferrato utilizzando il tool **hydra** contro il servizio RDP del target.

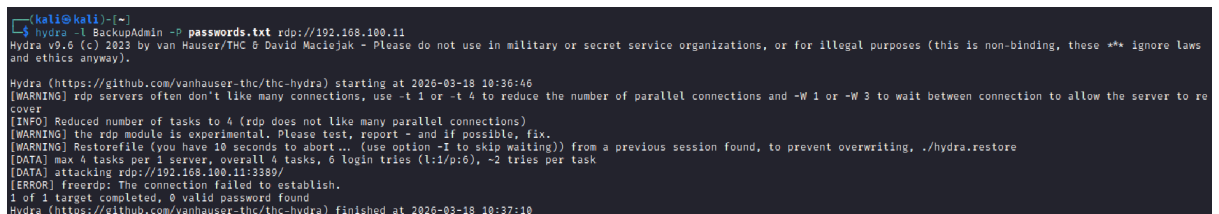


Figura 8: Lancio dell'offensiva Brute Force contro il protocollo RDP (porta 3389) del target utilizzando il framework Hydra.

7. Fase 5: Rilevamento e Risultato (Blue Teaming)

L'agente Wazuh ha immediatamente registrato l'anomalia, intercettando gli Event ID 4625 generati da Windows. La dashboard di Threat Hunting ha classificato l'evento come anomalia di Livello 5.

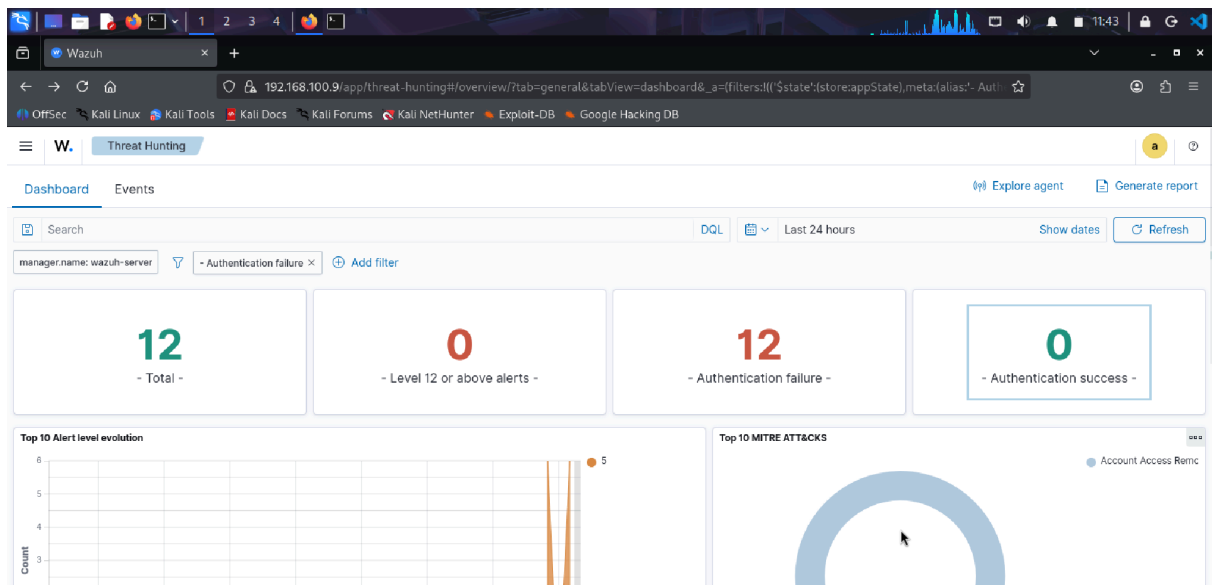


Figura 9: Rilevamento in tempo reale dei molteplici Event ID 4625 (Logon Failure) nella dashboard Threat Hunting di Wazuh.

In tempo reale, il demone integrator ha attivato il workflow di Shuffle. L'infrastruttura SOAR ha elaborato il dato inviando una notifica d'emergenza, formattata e leggibile, al canale SOC.

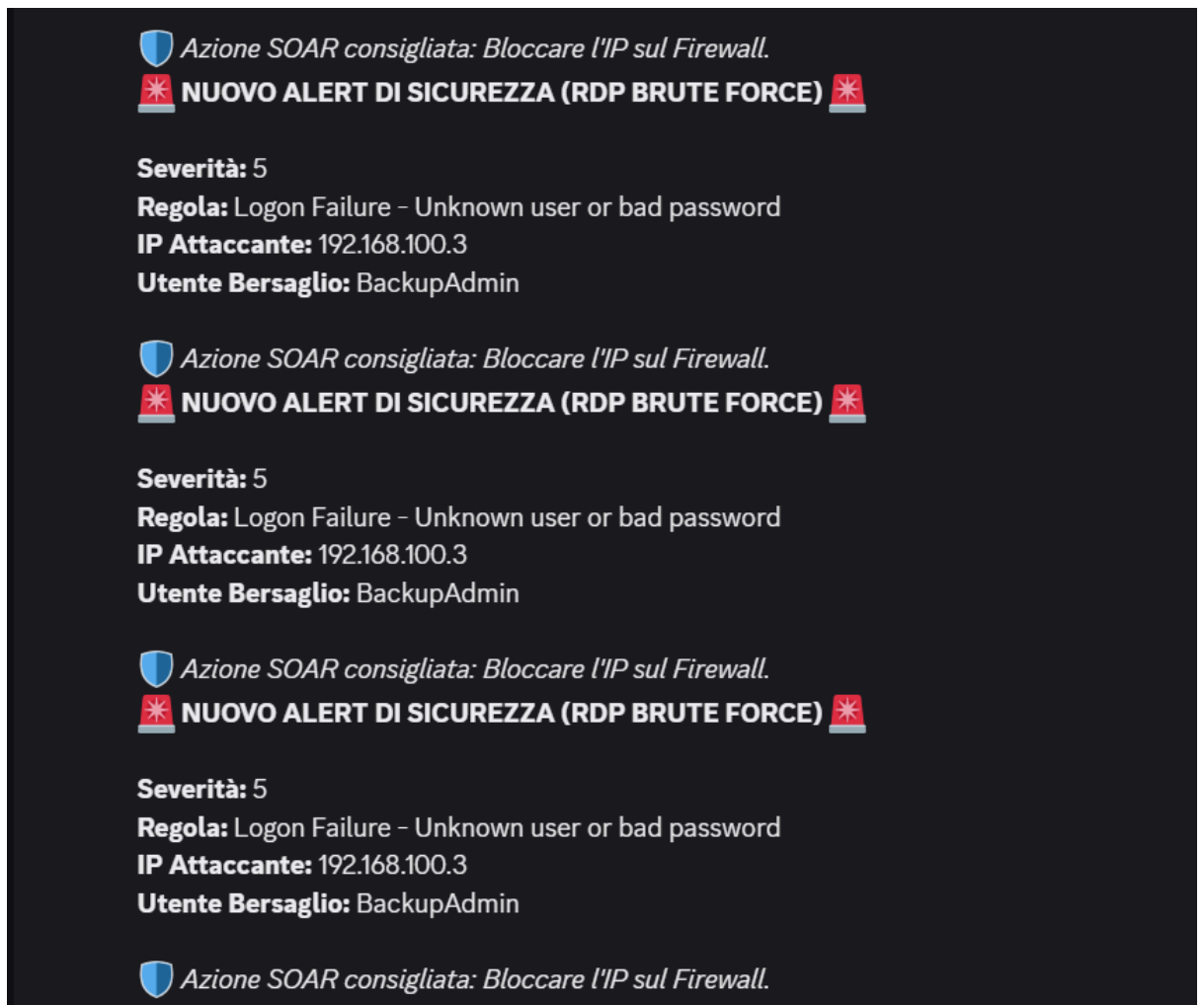


Figura 10: Ricezione dell'Actionable Alert sul canale Discord, arricchito dal SOAR con le telemetrie critiche dell'attaccante.

8. Conclusioni

Il test ha confermato la validità dell'architettura. L'integrazione tra log analysis (SIEM) e orchestrazione (SOAR) elimina il rumore di fondo per l'analista, fornendo esclusivamente un *Actionable Alert* contenente l'IP malevolo da bloccare sul firewall e il target compromesso.